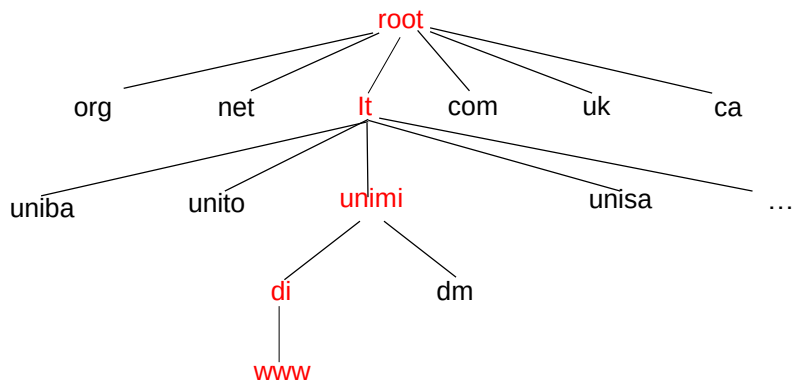


Sicurezza dei sistemi e delle reti

ATTACCHI AI SERVIZI: DNS

Domain Name System

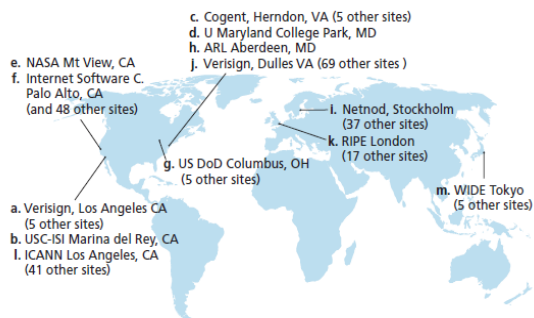
Hierarchical Name Space



DNS Root Name Servers

Servizio gerarchico:

- Root name servers per domini al top-level
 - In Internet ci sono 13 server DNS principali
 - rete di server replicati (247 in totale)
- Top-level domain (TLD) servers.
 - responsabili dei domini di primo livello come com, org, net, edu e gov e di tutti i domini di primo livello del paese come uk, fr, ca e jp
- Authoritative name servers per i sottodominii
 - authoritative DNS server per una organizzazione contiene i DNS records.
 - implementare il proprio authoritative server DNS o in alternativa avere questi record archiviati in un authoritative server DNS autorevole di qualche fornitore di servizi.
 - La maggior parte delle università e delle grandi aziende implementano e mantengono il proprio authoritative server DNS autorevole primario e secondario (backup).
- Local name resolvers contattano authoritative servers quando non conoscono un nome



DNS root servers in 2012

DNS Root Server



source: <https://root-servers.org/>

DNS Root Servers

List of Root Servers

Hostname	IP Addresses	Manager
a.root-servers.net	198.41.0.4, 2001:503:ba3e::2:30	VeriSign, Inc.
b.root-servers.net	192.228.79.201	University of Southern California (ISI)
c.root-servers.net	192.33.4.12	Cogent Communications
d.root-servers.net	199.7.91.13, 2001:500:2d::d	University of Maryland
e.root-servers.net	192.203.230.10	NASA (Ames Research Center)
f.root-servers.net	192.5.5.241, 2001:500:2f::f	Internet Systems Consortium, Inc.
g.root-servers.net	192.112.36.4	US Department of Defence (NIC)
h.root-servers.net	128.63.2.53, 2001:500:1::803f:235	US Army (Research Lab)
i.root-servers.net	192.36.148.17, 2001:7fe::53	Netnod
j.root-servers.net	192.58.128.30, 2001:503:c27::2:30	VeriSign, Inc.
k.root-servers.net	193.0.14.129, 2001:7fd::1	RIPE NCC
l.root-servers.net	199.7.83.42, 2001:500:3::42	ICANN
m.root-servers.net	202.12.27.33, 2001:dc3::35	WIDE Project

Terminologia

Zone

O "dominio": una collezione di coppie hostnames/IP gestite insieme.

Esempio: unixwiz.net, e tutti i record DNS simili — www.unixwiz.net, mvp.unixwiz.net, cs.unixwiz.net, etc. — fanno parte della "unixwiz.net zone"

Nameserver

Software server che risponde a domande DNS

- "Qual è l'indirizzo IP per www.unixwiz.net?".
- Alcune volte il nameserver conosce la risposta direttamente (è "authoritative" per la zona),
- Altre volte ridirige la domanda (recursive nameserver)
 - software che eseguono il servizio: [BIND](#), [PowerDNS](#), [djbdns](#)

Authoritative Nameserver

Per ogni zona bisogna mantenere un file delle associazioni hostnames e indirizzi IP

(linux.unixwiz.net is 64.170.162.98", etc).

Resolver

Parte client del Sistema DNS client/server: libreria compilata in un programma che richiede il servizio DNS sa come interrogare un nameserver

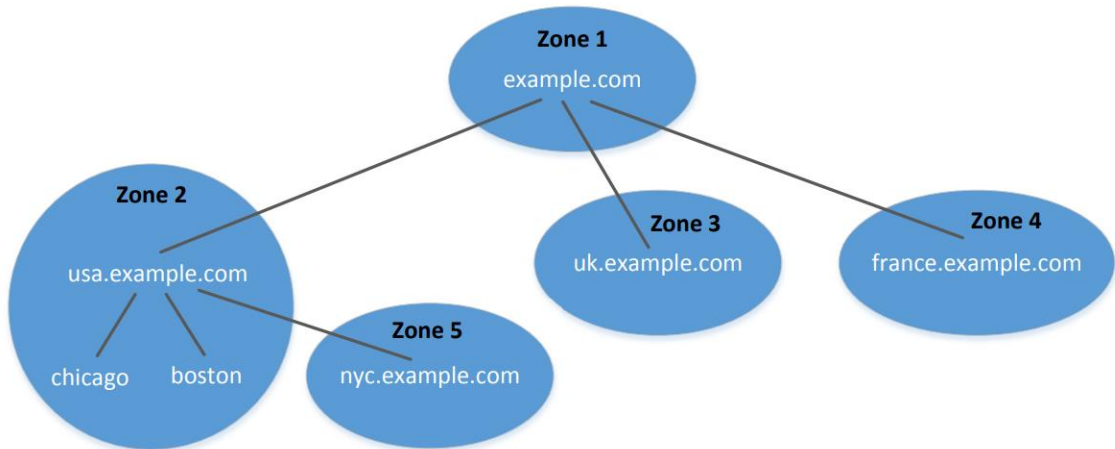
Resource Record

DNS è un database di "resource records" che contiene i campi:

(Name, Value, Type, TTL)

Il tipo comune è un IP Address (an "A" record), ma esistono altri tipi di records : NS (nameserver), MX (mail exchanger), SOA (Start of Authority), and so on.

DNS Zones



Risoluzione dei Nomi

Ogni computer ha una libreria per la risoluzione dei nomi

- gethostbyname in UNIX

Ogni resolver conosce un nome di un DNS server locale

Il Resolver manda una richiesta DNS al server

Il DNS server o dà la risposta o la inoltra ad un altro server, o da un referente

- Ossia il server successivo al quale la richiesta deve essere spedita

I resolver usano UDP (single name) o TCP (whole group of names)

Sapere l'indirizzo del root server è sufficiente

Recursive Query:

- Ritorna una risposta (non un referente)

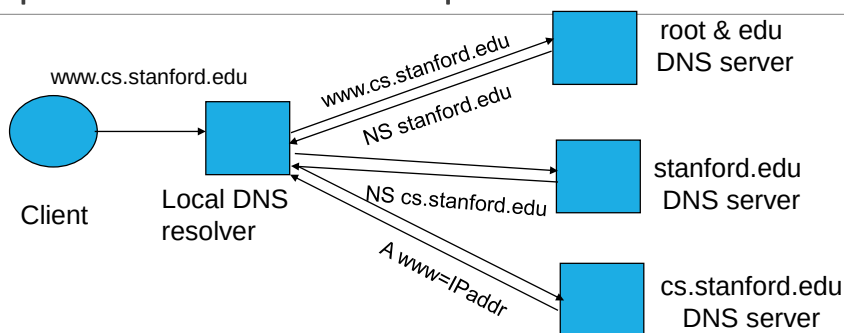
Iterative Query:

- Ritorna una risposta o un riferimento al prossimo server

Resolvers usano recursive query.

Servers usano iterative query.

Esempio di DNS Lookup



Tipi di DNS entry: Resource Records

DNS è usato non solo per l'associazione nome—Ip
Ma anche per trovare un mail server, pop server,

DNS record types:

NS: name server (points to other server)

A: address record (contains IP address)

MX: address in charge of handling email

CNAME Alias name (like a file link),

SOA Start of Authorities data sulla zona, come il contatto per admin, cosa fare se il master non è raggiungibile.

TXT generic text (e.g. used to distribute site public keys (DKIM))

Esempio: A e CNAME record



Seguendo una DNS query

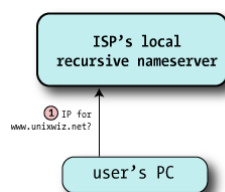
Il cliente ("User's PC") richiede **www.unixwiz.net**,

Indirizzato a nameserver fornito dal ISP.

- La richiesta è per **A record**, che rappresenta un indirizzo IP.

Il nameserver non è authoritative per **unixwiz.net**,

- Guarda nel local zone database.
- Non c'è alcun nome salvato nella cache
- Richiesta indirizzata su internet



Seguendo una DNS query

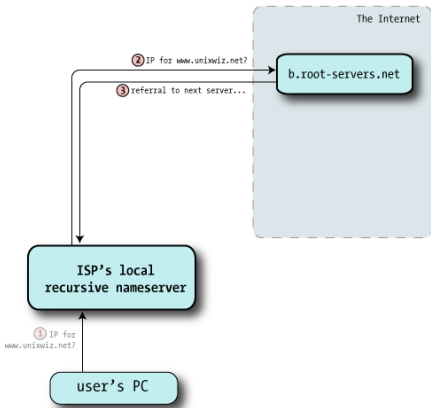
Tutti I nameservers ricorsivi hanno una lista con 13 root servers:

A.ROOT-SERVERS.NET. IN A 198.41.0.4
B.ROOT-SERVERS.NET. IN A 192.228.79.201
C.ROOT-SERVERS.NET. IN A 192.33.4.12
...
M.ROOT-SERVERS.NET. IN A 202.12.27.33

IP quasi fissi.

Il nameserver ne sceglie uno a caso

- Manda la query per il record A di **www.unixwiz.net**;
Es: **b.root-servers.net**



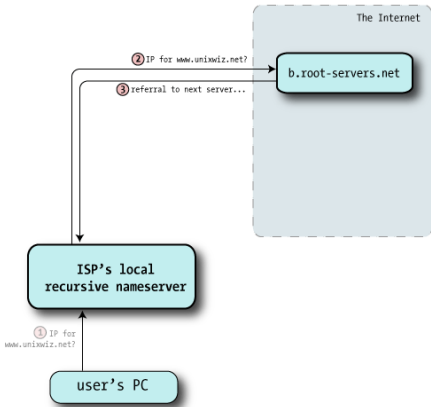
Seguendo una DNS query

Il root server non conosce **unixwiz.net**

- Ridirige al Global Top Level Domain (GTLD) responsabile per I domini **.net**.
- **NS** records più qualificati per rispondere alla query:

```
9 .NET referrals
/* Authority section */
NET.      IN      NS      A.GTLD-SERVERS.NET.
          IN      NS      B.GTLD-SERVERS.NET.
          IN      NS      C.GTLD-SERVERS.NET.
          ...
          IN      NS      M.GTLD-SERVERS.NET.

/* Additional section - "glue" records */
A.GTLD-SERVERS.net.  IN  A  192.5.6.30
B.GTLD-SERVERS.net.  IN  A  192.33.14.30
C.GTLD-SERVERS.net.  IN  A  192.26.92.30
...
M.GTLD-SERVERS.net.  IN  A  192.55.83.30
```



Seguendo una DNS query

Il nameserver sceglie uno degli authoritative servers a caso

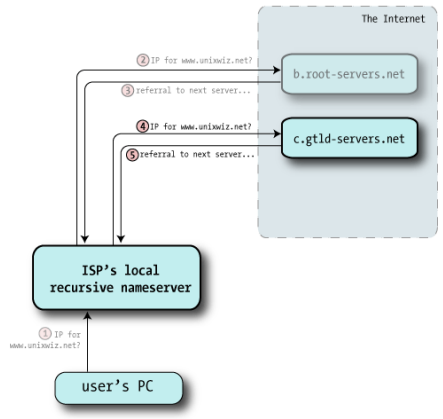
- **c.gtld-servers.net**
- Forwarda la richiesta per A record di **www.unixwiz.net?**

Il GTLD server non conosce la risposta

- Come il root server, ridirige ad un referral (a set of NS records) che hanno la risposta cercata.

```
⌘ unixwiz.net referral
/* Authority section */
unixwiz.net.      IN  NS  cs.unixwiz.net.
                  IN  NS  linux.unixwiz.net.

/* Additional section - "glue" records */
cs.unixwiz.net.   IN  A   8.7.25.94
linux.unixwiz.net. IN  A   64.170.162.98
```



Seguendo una DNS query

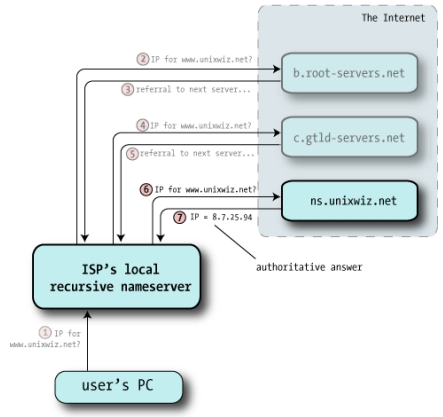
Il recursive nameserver sceglie uno dei nameservers a caso e manda una terza query

A questo punto otteniamo una risposta:

A record for www.unixwiz.net.

Alcuni flag indicano "This is an authoritative response",

- La risposta proviene da una delle sorgenti fidate per quel dominio



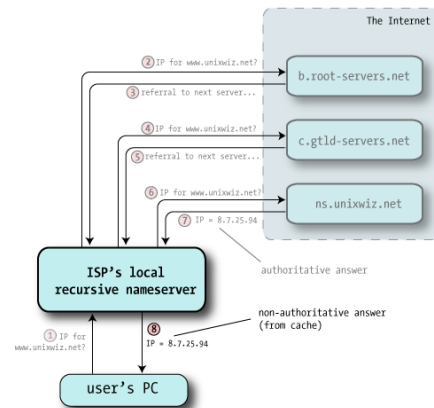
Seguendo una DNS query

Il recursive nameserver del ISP

- Riporta la risposta al client
- Memorizza nella cache

Alcuni flag non sempre riportati

- "authoritative"
- Risposta considerata non-authoritative.

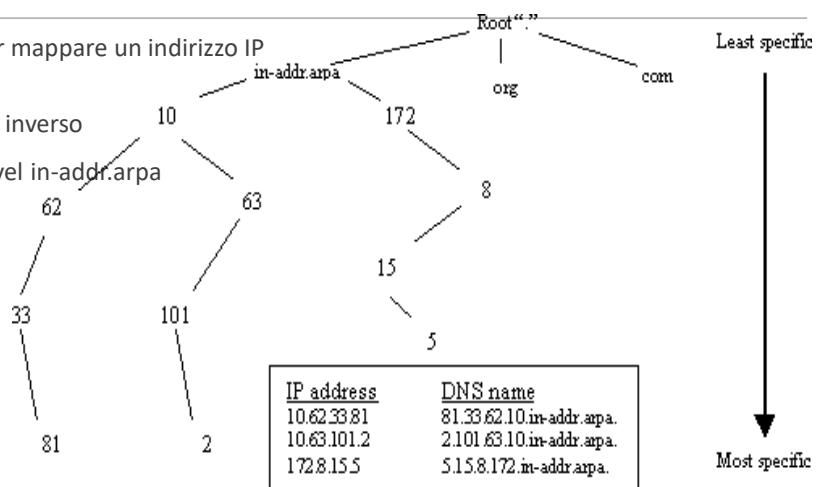


Risoluzione inversa

DNS è usato anche per mappare un indirizzo IP in un host name

IP sono usati in ordine inverso

C'è un dominio top-level in-addr.arpa



Servizio DNS

Il servizio viene eseguito 1000 miliardi di volte al giorno

- Deve essere veloce
- 8-packet handshake si completa in meno di un secondo

Il DNS ha natura distribuita:

- Nessuna macchina sa tutto
- Ciascuna sa come trovare l'altra con la delegation.

Attenzione: un nameserver potrebbe dichiarare qualsiasi zona

- Anche quelle che non possiede. Un attaccante potrebbe settare un nameserver come authoritative zone per **bancaitalia.it**
 - Nessun effetto, nessun nameserver ad alto livello lo delega.



Ottimizzazione dei DNS

Si utilizza:

- Spatial Locality: I computer locali sono interrogati più di quelli remoti
- Temporal Locality: lo stesso set di domini viene interrogato ripetutamente, si usa Caching

Ogni entry ha un time to live (TTL)

Replication: Multipli servers. Multiple radici.

Si contatta il server geograficamente più vicino



Messaggi DNS

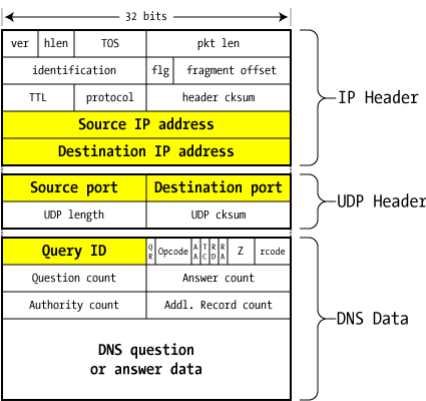
Il DNS ha un tipo di messaggio che contiene 5 parti:

- Header section
 - Tipo del messaggio e contenuto
- Question section
 - Informazioni sull'oggetto della query
- Answer section,
 - RR relativi alla risposta
- Authority section
 - SOA o NS record
- Additional section
 - Informazioni aggiuntive

Pacchetti DNS

DNS server sono in ascolto sulla porta 53/udp

- Query ID
 - Identificatore unico, permette al server di associare la richiesta alla risposta
 - Chiamato anche Transaction ID (TXID).
- Flags
 - QR (Query / Response) **0** query, **1** response
 - Opcode **0** for a standard query
 - AA (Authoritative Answer)
 - RD (Recursion Desired)
 - RA (Recursion Available)
 - Z — reserved must be zero
 - rcode success or failure



(from Steve Friedl)

Pacchetti DNS

Question record count

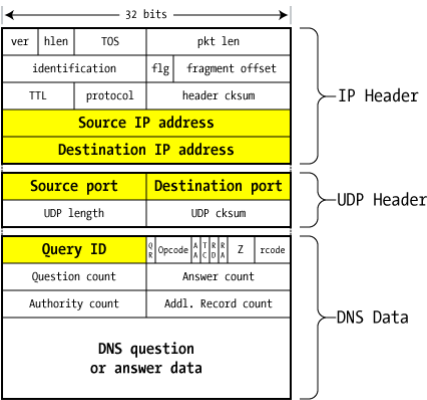
- Cosa sta cercando: nome (**www.unixwiz.net**), tipo (**A, NS, MX**, etc.), classe (sempre **IN**=Internet).
- question count quasi sempre **1**.

Answer/authority/additional record count

- Includono diverse risposte aggizionali dal client

Question/Answer data

- Contiene la richiesta o la risposta



(from Steve Friedl)

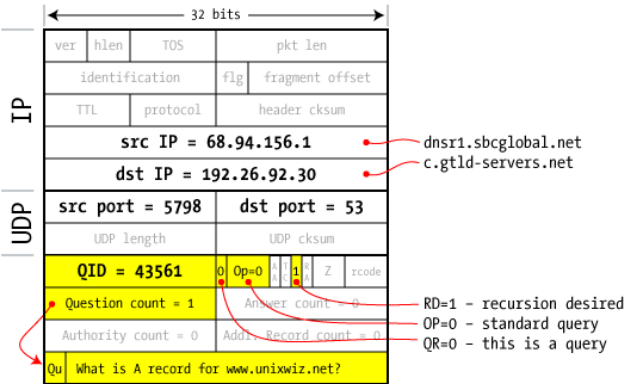
Resolver to NS request

ISP nameserver (**dnsr1**) chiede un root server per **www.unixwiz.net**,

Risponde con una lista di global top-level domain server per **.net**

Tra questi, il nameserver ne sceglie uno, (**c.gtld-servers.net**)

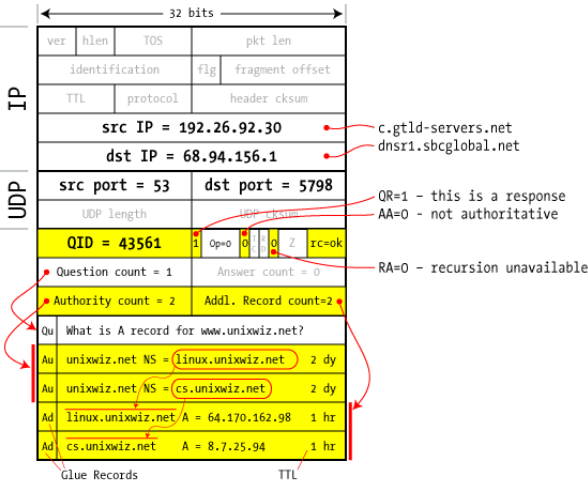
Question contiene la richiesta per **A record** **www.unixwiz.net**.



Response to resolver

GTLD server risponde con una serie di NS record

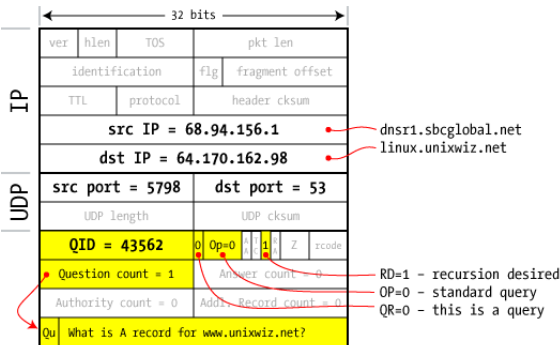
Nella parte Authorities **cs.unixwiz.net** and **linux.unixwiz.net**.



client to server

Si interrogano i nameserver

Query ID incrementato di 1

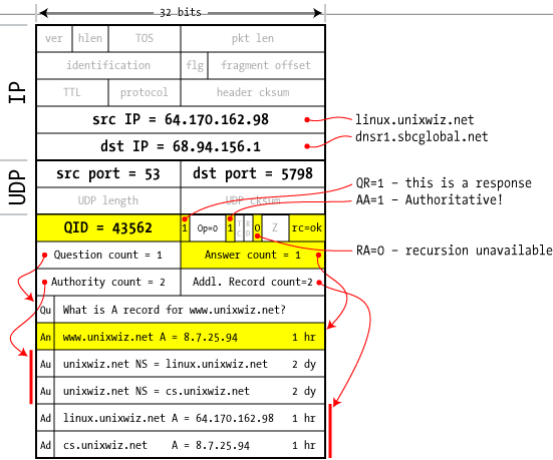


server to client

answer count=1,

Contiene un **A record** con l'IP cercato

AA=1 che è un **authoritative** answer



Caching

Le risposte del DNS vengono messe in cache

- Risposte veloci per richieste ripetute
- Anche I record per I nameserver sono messi in cache

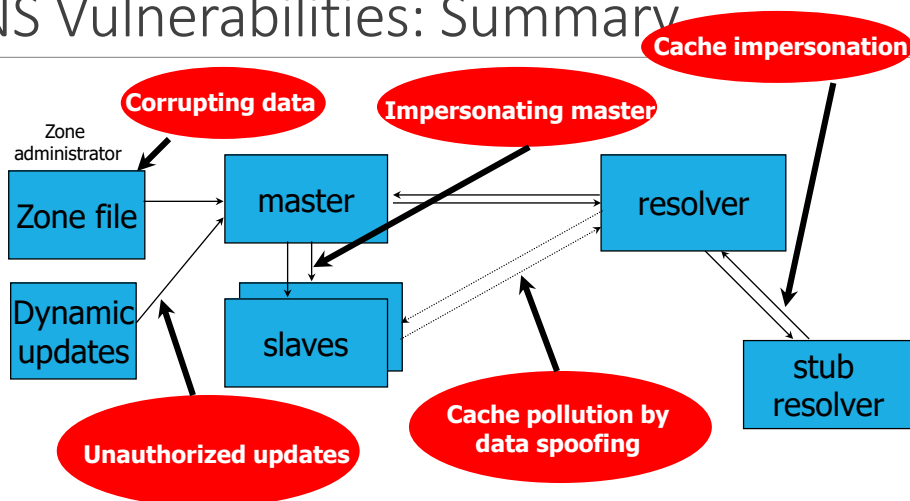
Anche le query con esito negative sono messe in cache

- Si risparmia tempo, anche in caso di errore es. misspelling

I dati in cache dopo un po' esirano

- Lifetime (TTL) dei dati controllati dal possessore dei dati
- Il valore TTL è passato con ogni record

DNS Vulnerabilities: Summary



slide 29

Cache poisoning

- Scopo è inserire false informazioni nella cache del nameserver ricorsivo
- Tutti i suoi "clienti" riceveranno falsi IP per un certo nome inconsapevolmente

Il DNS accetta solo **risposte a query in attesa**;

- Risposte non desiderate vengono ignorate.

La risposta deve arrivare sulla stessa porta UDP

- In modo da recapitarla al processo del nameserver in attesa

La parte **Question**

- È duplicata nella risposta e deve fare match con la richiesta.

Il **Query ID** fa match con la query in attesa

Le parti Authority e Additional contengono nomi nello stesso dominio della richiesta

- "bailiwick checking".
- Per evitare che **ns.unixwiz.net** ritorni non solo IP per **www.unixwiz.net**, ma anche false info per esempio **BankOfSteve.com**.

Attacco: indovinare il Query ID

Nei vecchi nameservers Query ID è incrementato di 1

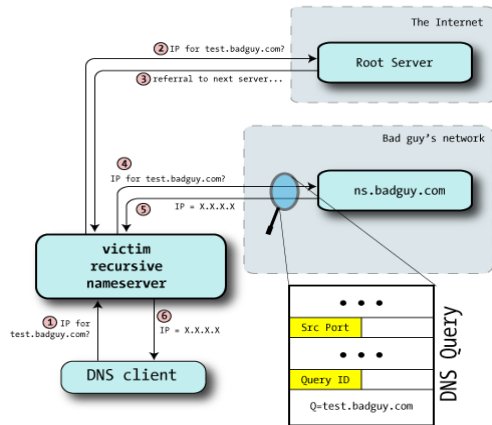
- Facile indovinare il numero
- Basta fare una richiesta su un dominio controllato dall'attaccante (**test.badguy.com**).

Il nameserver della vittima riceve la richiesta e inizia la risoluzione

Alla fine, viene diretto al nameserver dell'attaccante

- authoritative per **badguy.com**.

Basta monitorare la richiesta a **test.badguy.com** o sniffare il traffico IP per scoprire la porta e il Query ID.



Version 1

Step 1 — Attaccante manda una DNS query al nameserver della vittima per lo hostname da ridirigere

Step 2a — so che la vittima richiederà **ns1.bankofsteve.com**. L'attaccante inizia a spedire un flusso di pacchetti DNS di risposta con incluso l'IP del webserver falso.

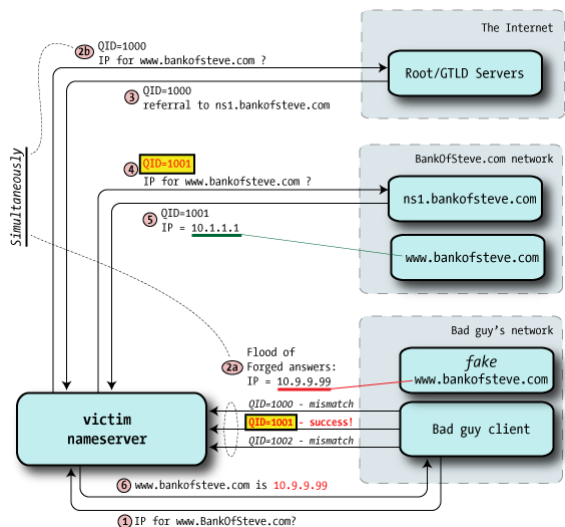
Steps 2b & 3 — Root/GTLD servers restituiscono il referral per **ns1.bankofsteve.com**.

Step 4 — Il nameserver della vittima chiede a **ns1.bankofsteve.com** per l'IP di **www.bankofsteve.com**, e usa query ID 1001 (uno in più della precedente query).

Step 5 — Il vero nameserver ritorna la risposta corretta con QID=1001. MA se l'attaccante ha fatto match col the query ID prima in **2a** la risposta arriva troppo tardi ed è ignorata.

Step 6 — Col falso IP (bad guy's webserver) in cache si ritorna la risposta "avvelenata" al DNS client..

Step 7 (...) — In futuro i client del DNS che chiedono **www.bankofsteve.com** riceveranno la stessa risposta fraudolenta



Punti essenziali

Il nome non può essere nella cache

Se `www.bankofsteve.com` è nella cache devo aspettare il TTL.

Bisogna indovinare il query ID

Facile con I vecchi nameserver

Bisogna essere più veloci del vero nameserver

Se il nameserver della vittima e quello vero sono vicini la finestra di attacco può essere molto piccolo

Attaccare authority record

Dan Kaminsky

Configurazione di un nameserver authoritative per `bankofsteve.com` zone,

Step 1 — l'attaccante richiede un nome a caso nel dominio target (`www12345678.bankofsteve.com`),

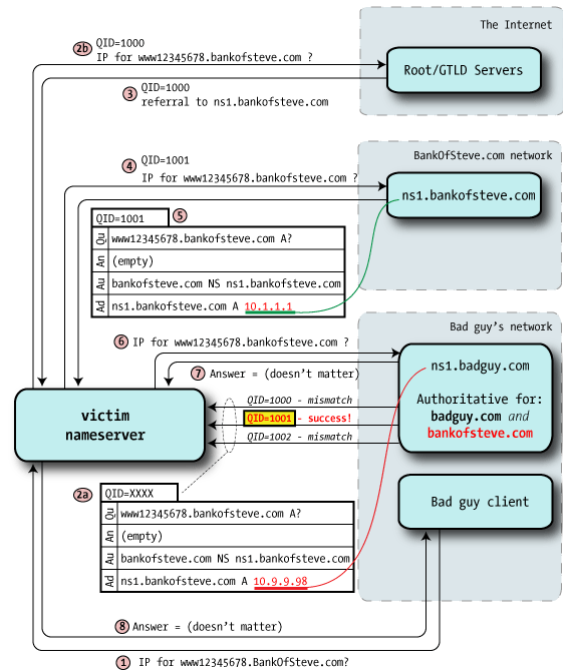
- Non deve essere nella cache

Step 2a — l'attaccante manda un flusso di pacchetti

- Ma delega a un altro nameserver via Authority records. "I don't know the answer, but you can ask over there"

I dati contengono il vero nameserver per `bankofsteve.com` nameserver ma la glue punta agli IP dell'attaccante.

La vittima crede che il nameserver dell'attaccante è authoritative per `bankofsteve.com` e adesso "possiede" tutta la zona



Punti essenziali

Tutti possono configurare un proprio nameserver

- authoritative per qualsiasi dominio
- Inutile perché non verrà puntato

Attacco pericolosissimo:

Controllando il dominio, l'attaccante controlla tutta la risoluzione del nameserver.

- Ridirige i visitatori del web (es **google.com**),
- Dirige email ai propri server con falsi MX records.

L'attaccante setta un TTL molto alto

- Falsi dati in cache più a lungo.

Si può attaccare un dominio di alto livello
.COM, .NET etc.

Tutti i nomi sotto il top level, sono dirottati

- Sforzo per soddisfare tutte le richieste

DNS Vulnerabilità

Sia gli utenti che gli host si fidano del mapping host-address restituito dal DNS:

- Si usa per politiche di sicurezza
- Browser same origin policy, URL address bar

Problemi

- Intercettare richieste o compromissione del server DNS in risposte sbagliate o maliziose
 - e.g.: un access point malizioso in un Internet point
- Soluzione – autenticazione delle richieste e delle risposte
 - DNSsec ... non molto in uso

Serie di query

Si può dirottare una singola query

- A causa del Query ID randomization difficile che l'attaccante indovini su 64k IDs.

L'attaccante genera una serie di query,

- Una per un nome casuale sotto lo stesso dominio
- **La prima richiesta avvia la risoluzione**
- **Alla fine in cache ns1.bankofsteve.com.**
- Dopo le richieste vanno direttamente a quel nameserver.

La richiesta successiva per un nome casuale (che non è sicuramente nella cache) causa una richiesta a **ns1** server.

L'attaccante invia un flusso di dati falsi verso la vittima

Esempio: se genera 50 false risposte per ogni nome casuale prima che la vera risposta arrivi il successo probabile

- in 10 secondi.

Triggering a Race

Ogni link, ogni immagine, ogni ad, può provocare un DNS lookup

- Non c'è bisogno di JavaScript

Anche i mail servers possono iniziare una richiesta

- On first greeting: HELO
- On first learning who they're talking to: MAIL FROM
- On spam check
- When trying to deliver a bounce
- When trying to deliver a newsletter
- When trying to deliver an actual response from an actual employee

Difese

Aumentare la taglia delle Query ID

Si aggiunge una porta casuale, in più 11 bits

- L'attacco dura diverse ore

Richiedi ogni query due volte :

- L'attaccante deve indovinare il QueryID due volte (32 bits)
- ... troppo overhead

$$\begin{array}{c} 2^{16} \times 2^{11} = 2^{27} = 134 \text{ million} \\ \text{└───┘} \quad \text{Source ports} \\ \text{└───┘} \quad \text{Query ID} \end{array}$$

www.nasty.dom NS ns1.yahoo.com

www.nasty.dom NS ns2.dca.yahoo.com

www.nasty.dom NS ns3.europe.yahoo.com

www.nasty.dom NS ns5.dcx.yahoo.com

ns1.yahoo.com A 1.2.3.4

ns2.dca.yahoo.com A 1.2.3.4

ns3.europe.yahoo.com A 1.2.3.4

ns5.dcx.yahoo.com A 1.2.3.4

Caches devono scartare info su yahoo.com
eccetto che da yahoo.com servers, com servers, e
root servers.

DNS poisoning attacks

Gennaio 2005

- il nome di dominio di un grande ISP di New York, Panix, è stato dirottato su un sito in Australia.

Novembre 2004,

- Gli utenti di Google e Amazon sono stati inviati a Med Network Inc., una farmacia online

Marzo 2003,

- un gruppo soprannominato "Freedom Cyber Force Militia" ha dirottato i visitatori del sito Web di Al-Jazeera e ha presentato loro il messaggio "God Bless Our Troops"

Luglio 1997

- Utilizzato da Kashpureff per reindirizzare InterNIC al suo AlterNIC (per protestare contro il controllo di InterNIC sul DNS)

Reverse DNS Spoofing

Un accesso fidato spesso si basa sul nome dell' host

- Esempio: accesso permesso a tutti gli host in .rhosts di lanciare una remote shell

Le richieste rsh o rlogin arrivano da indirizzi sorgente numerici

- Il sistema esegue un reverse DNS lookup per determinare l'host name del richiedente e controllare se è in.rhosts

Se un attaccante può cambiare la risposta ad una reverse DNS query, può ingannare la macchina target

- Pensa che la richiesta venga da una fonte autorizzata
- Nessuna autenticazione per le risposte DNS
- no double-checking (numeric → symbolic → numeric)

slide 41

Altri Attacchi contro Name Server

Attacco Denial of Service (DOS) "Exploit to fail"

- Sfrutta una vulnerabilità in alcuni elementi di un'infrastruttura di server dei nomi per causare l'interruzione del servizio di risoluzione dei nomi

Attacco DOS "Exploit to own"

- Sfrutta una vulnerabilità in alcuni elementi di un'infrastruttura di server dei nomi per ottenere privilegi amministrativi di sistema

Reflection and Amplification attack

- Attacco DOS distribuito

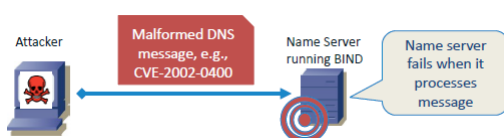
Attacco di esaurimento

- L'aggressore inonda il ricorsore con query DNS per nomi di dominio inesistenti
- Il ricorsore tenta di risolvere le query e aggiunge ogni risposta NXDOMAIN alla cache
- La cache di Recursor si riempie di risposte inutili
- L'elaborazione di query DNS legittime è ridotta

“Exploit To Fail” DOS Attack

Sfrutta una vulnerabilità in alcuni elementi di un'infrastruttura di server dei nomi per causare l'interruzione del servizio di risoluzione dei nomi

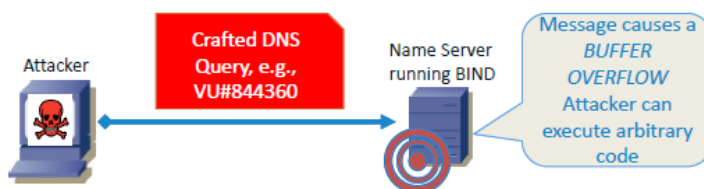
- Esempio: iniezione di messaggi DNS dannosi
- <http://www.cvedetails.com/cve/CVE-2002-0400/>



“Exploit To Own” DOS Attack

Sfrutta una vulnerabilità in alcuni elementi di un'infrastruttura di server dei nomi per ottenere privilegi amministrativi di sistema

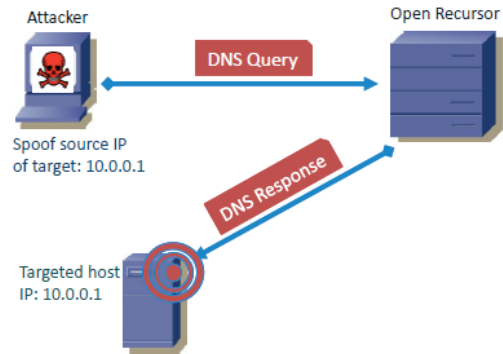
- Esempio: esecuzione di codice arbitrario / remoto
- <http://www.kb.cert.org/vuls/id/844360>



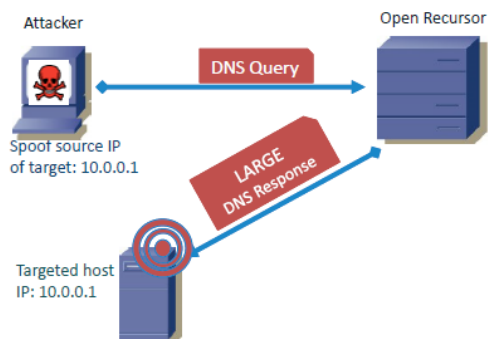
Reflection Attack

Attaccante falsifica l'indirizzo IP dell'host target

- L'aggressore invia messaggi DNS al recursor
- Recursor invia la risposta all'host mirato
- Risposta consegnata all'host target



Reflection And Amplification Attack



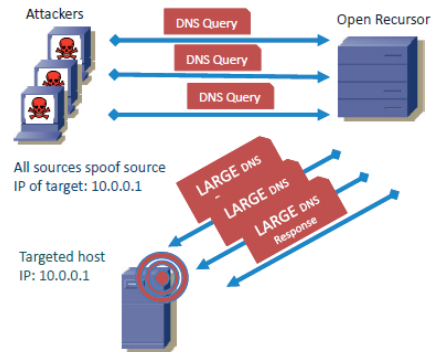
L'attaccante falsifica l'indirizzo IP dell'host target

- L'aggressore invia messaggi DNS al ricorsore che sollecita una risposta LARGE
- Recursor invia risposte LARGE all'host target
- Le risposte LARGE consumano le risorse dell'obiettivo più velocemente

Distributed Reflection And Amplification Attack

Lancia attacchi di riflessione e amplificazione da migliaia di origini

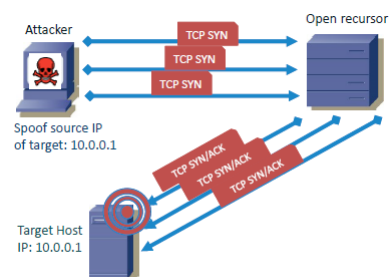
- Rifletti tramite ricursori aperti
- Fornire migliaia di risposte di grandi dimensioni al target



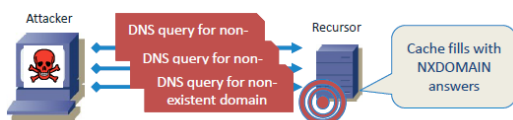
Resource Depletion DOS Attack

L'aggressore invia un flusso di messaggi DNS su TCP dall'indirizzo IP contraffatto del bersaglio

- Il server dei nomi alloca le risorse per le connessioni finché le risorse non sono esaurite
- La risoluzione dei nomi è ridotta o interrotta



NXDOMAIN Cache Exhaustion



L'aggressore inonda il ricorsore con query DNS per nomi di dominio inesistenti

- Recursor tenta di risolvere le query e aggiunge ogni risposta NXDOMAIN alla cache
- La cache di Recursor si riempie di risposte inutili
- L'elaborazione di query DNS legittime è ridotta

Altre vulnerabilità DNS

Implementazioni del DNS hanno vulnerabilità

- Reverse query buffer overrun nelle vecchie release di BIND
- MS DNS for NT 4.0 va in crash se alcuni flussi chargen

Denial of service

- Oct '02: attacco basato su ICMP compromise 9 root servers per 1 ora

Si possono usare richieste "zone transfer" per scaricare il database del DNS database e fare una mappa della rete (interna)

- "The Art of Intrusion": NYTimes.com and Excite@Home
- Soluzione: bloccare la porta 53 sui name servers aziendali

See <http://cr.yp.to/djbdns/notes.html>

Pharming

La parola deriva da **farming**, *esternalizzazione*, sul modello di **phishing/fishing**.

- Molte difese anti-phishing si basano sul DNS

Si possono avere:

- Entry non corrette in un **hosts file** di un computer
- Compromissione di un router di un local **network**

Uno scenario che include JavaScript per cambiare il DNS server del router

- Chiamato drive-by pharming dimostrato by Stamm, Ramzan e Jakobsson in Dec. 2006.

Le difese si bypassano avvelenando la DNS cache e/o falsificando le risposte

- Browser: "give me the address of www.paypal.com"
- Attacker: "sure, it's 6.6.6.6" (attacker-controlled site)

Dynamic pharming

- Si fornisce un falso DNS mapping per un server fidato, download di uno script malizioso
- Si forza l'utente a fare il download dal vero server, fornendo temporaneamente un DNS mapping corretto
- Lo script e il contenuto hanno la stessa origine
- DNS configuration change by compromising a D-Link DI-524.Ex: `<script src = "http://192.168.0.1/h wan dhcp.cgi?dns1=69.6.6.6"></script>`

slide 51

DNS rebinding

DNS rebinding

Web browsers in genere aderiscono alla **same origin policy**:

- Un applet si può connettere solo al server dal quale è stato scaricato.

Per eseguire la connessione il browser ha bisogno dell'IP del server.

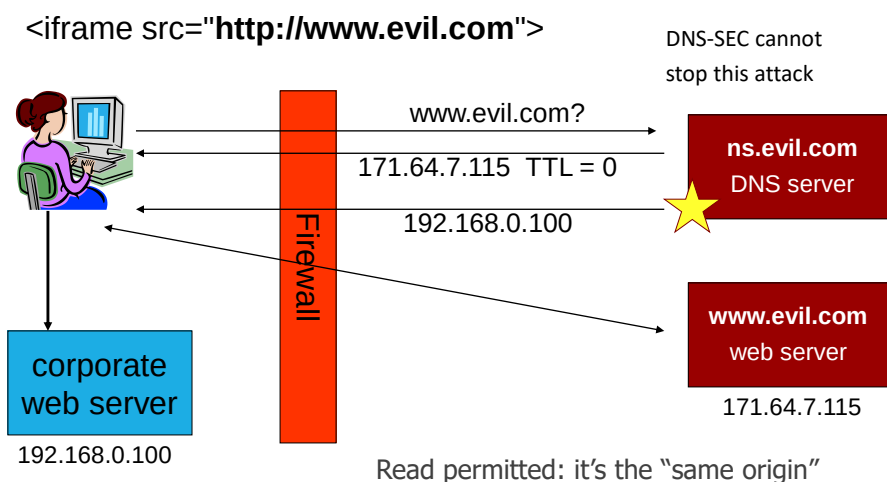
Authoritative DNS server associa i nomi nel DNS a indirizzi IP.

Il browser si fida del DNS server

- Quando aderisce alla same origin policy.

1. Attaccante crea il dominio **attacker.org**;
2. Lega il nome a due indirizzi IP,
 1. Il proprio e l'indirizzo della vittima
3. Il Client scarica l'applet da **attacker.org**;
 1. applet si connette al target;
 1. Permessi da same origin policy.

DNS Rebinding Attack



DNS rebinding attack

1996 - Java Applets

Princeton's Secure Internet Programming group first mentioned the attack method in 1996

Next round: Javascript, 2001.

Client visits [attacker.org](#); attacker's DNS server resolves this name to attacker's IP address with short time-to-live.

Attacker rebinds [attacker.org](#) to target's address.

Malicious script connects to [attacker.org](#), which now is resolved to the target's address.

Defence: Do not trust server on time-to-live; keep time yourself and [pin](#) host name to original IP address.

- J. Roskind: [Attacks against the Netscape browser](#). in RSA Conference, April 2001.

Rebinding History

In 2006, Martin Johns scopre una tecnica che fa sì che Firefox e Internet Explorer rilascino ogni mapping domain to-IP,

- Ossia riabilitano il rebinding attack per JavaScript.

Nei mesi seguenti, altri DNS Rebinding attack sono scoperti:

- Kanatoko per Flash applets
- Johns and Kanatoko per LiveConnect JavaScript come utilizzare alcuni metodi Java in rebinding attacks

Altri metodi di DNS Rebinding attacks per Java Applets:

- Rios and McFeters ingannano la cache di un applet Java usando multiple istanze della Java VM
- David Byrne ha sfruttato il mismatch di un canale di comunicazione se la VM accede alla rete via Web proxy

DNS rebinding attack

CCS 2013 : attacco contro HTML5

- Sfrutta la Application Cache
- Funziona con tutti i browser, bypassando le difese ed influisce sugli scripting runtime environments (JavaScript, Flash, Silverlight).

Paper: Eradicating DNS Rebinding with the Extended Same-Origin Policy Martin Johns and Sebastian Lekies,

Problemi:

- Path di comunicazione tra i plug-in.
- Ogni plug-in ha il proprio pinning database.

Controdifese:

- Pinning fatto direttamente dai plug-in del browser.

Sistemi di autorizzazione più sofisticati:

- Client si riferiscono alle info del DNS server.

Un esempio pratico

Bang & Olufsen speakers in home network

- They connect via Ethernet or WiFi, saving the password you input the first time you plug them, and come with a nice web interface.
- /1000/Bo_network_settings.asp (no login needed)

Attacco

A victim visits a malicious website, let's say attacker.com,

- A DNS record with a very short Time To Live (TTL), such as 60 seconds.
- The HTML page served contains a malicious Javascript payload, to get the internal IP address of the machine
- We now know the B&O device internal IP address (let's say, for example, 192.168.1.10) send it to an **attacker-controlled backend**
- The script running on the backend changes the DNS record of the website to 192.168.1.10.

Attacco

The minute passes, and the script tries to get http://attacker.com/1000/Bo_network_settings.asp,

- the DNS cache is expired,
- the browser performs a new DNS request
- attacker.com now resolves to 192.168.1.10.
- Since the browser thinks we still are on the same origin, it will happily read the response.



Attacchi con rebinding

Firewall Circumvention.

L'attaccante usa il DNS rebinding per accedere alle macchine che sono dietro un firewall

IP Hijacking.

L'attaccante usa il DNS rebinding per accedere pubblicamente a server usando l'IP del client. Il beneficio si ha nella fiducia che proviene dall'IP del client.



Passare il firewall

Spidering the Intranet.

- L'attaccante indovina il nome di una macchina interna (usa CNAME per rebind tra attacker.com e hr.company.com), il resolver ritorna l'IP
 - Evita lo scan degli IP interni
- Si può connettere al server (es. web server non protetto)

Compromising Unpatched Machines

- Macchine interne sono meno protette
 - Patching non aggiornato, exploit di una macchina dietro il firewall

Abusing Internal Open Services

- Alcuni servizi sono aperti per uso interno
- stampanti, ftp server, etc
- Router e servizi con password default

IP Hijacking

Committing Click Fraud

- Si generano falsi click con IP diversi

Sending Spam

- Alcuni indirizzi IP sono in blacklist per lo spam
- Si usa IP del client per spedire spam (si connette alla porta 25 Java e Flash lo permettono)
 - Utilizzano il pop server del client

Defeating IP-based Authentication

- Accesso a biblioteche, etc

Framing Clients

- Si attacca usando l'IP del client
 - La colpa ricade sul suo IP
- Se si usa HTTPS non si lascia traccia

DNS Rebinding Defenses

Browser mitigation: DNS Pinning

- Rifiuta di passare a un nuovo IP
- Interagisce male con proxy, VPN, DNS dinamico, ...
- Non implementato in modo coerente nei

Difese lato server

- Controlla l'intestazione host per domini non riconosciuti
- Autentica gli utenti con qualcosa di diverso dall'IP

Difese firewall

- I nomi esterni non possono essere risolti in indirizzi interni
- Protegge i browser all'interno dell'organizzazione

DNSSEC

Internet Engineering Task Force ha definito DNSSEC.

- Si basa su public key cryptography per la verifica dei dati DNS.
- Autenticazione e integrità
- chain of trust che parte
 - Dalla radice attraverso la gerarchia di risoluzione
 - Ad ogni livello nel DNS, la firma del livello superiore è verificata usando una chiave pubblica associata
- Definita in RFC 4033
 - "The Domain Name System (DNS) security extensions provide origin authentication and integrity assurance services for DNS data, including mechanisms for authenticated denial of existence of DNS data."

RFC 4033: DNSSEC Introduction

- RFC 4034: Resource Records for DNSSEC
- RFC 4035: DNSSEC - Protocol modifications
- RFC 5155: Hashed Authenticated Denial of Existence (NSEC3)
- RFC 6781: DNSSEC Operational Practices
- RFC 6840: Clarifications & Implementation Notes for DNSSEC

-

DNSSEC – protezioni offerte

Nessun cambiamento al formato del pacchetto

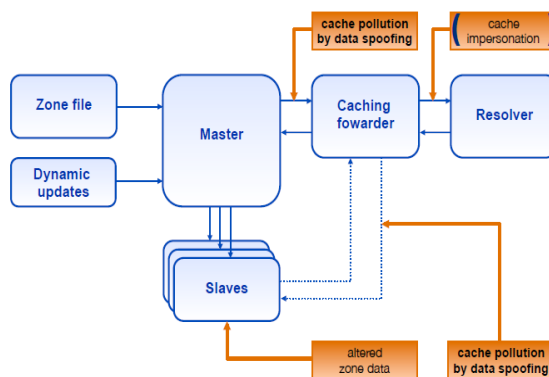
- Goal è la sicurezza dei dati DNS, non la sicurezza del canale

Nuovi Resource Records (RRs)

Lookup referral chain (unsigned)

Origin attestation chain (PKI) (signed)

- Start at pre-configured trust anchors
 - DS/DNSKEY of zone (should include root)
- DS → DNSKEY → DS forms a link



DNSSEC

Ogni zona ha una coppia di chiavi pubblica e privata

- Il proprietario della zona utilizza la chiave privata per firmare i dati della zona, producendo firme digitali per ogni set di record di risorse
- La chiave pubblica viene utilizzata da altri (risolutori DNS) per convalidare le firme (prova di autenticità)
- La chiave pubblica è pubblicata nella zona stessa in modo che i resolver possano trovarla
- Le chiavi pubbliche della zona sono organizzate in una catena di fiducia che segue il normale percorso di delega DNS
- I risolutori DNS autenticano le firme DNS dalla radice alla zona foglia contenente il nome.

One or more DNSKEY at the zone apex

- One or more NSEC for every DNS name
- One or more RRSIG for every RR set
- One or more DS records for every secure delegation

DNSSEC Record

DNSKEY	Contains zone public key
RRSIG	Contains DNSSEC signature
NSEC	Points to next name in zone (used for authenticated denial of existence)
DS	Delegation Signer (certifies public key for subordinate zone)
NSEC3	Enhanced version of NSEC (provides zone enumeration protection and opt-out)
NSEC3PARAM	NSEC3 parameters

Extended DNS

I messaggi DNS più grandi di 512 byte richiedono:

- Utilizzo di TCP (in genere risposta UDP troncata seguita da un nuovo tentativo TCP)
- EDNS0 - un meccanismo di estensione DNS che consente la negoziazione di dimensioni maggiori Buffer dei messaggi UDP
- RFC 6891 "Meccanismi di estensione per DNS (EDNS0)
- Per DNSSEC, EDNS0:
- Negoziazione di carichi utili UDP più grandi
- Flag per indicare che l'interrogante è in grado di elaborare i record DNSSEC: il Bit "DNSSEC OK" o "DO"

New Header Flags: CD, AD

- AD - "Authenticated Data"
- CD - "Checking Disabled"

Il flag AD

AD - *"Authenticated Data"*

Resolver imposta questo flag nelle risposte quando il record interrogato è firmato con una firma valida e non scaduta e una catena di fiducia autenticata fino a un ancoraggio di fiducia configurato (che potrebbe essere la chiave radice preconfigurata / tracciata)

Tutti i dati nelle sezioni risposta e autorità incluse sono stati adeguatamente autenticati dal risolutore

Può anche essere impostato in una query DNS - per indicare che l'interrogante comprende le risposte con il bit AD (ad es. Se desidera uno stato autenticato ma non necessariamente DNSSEC RR)

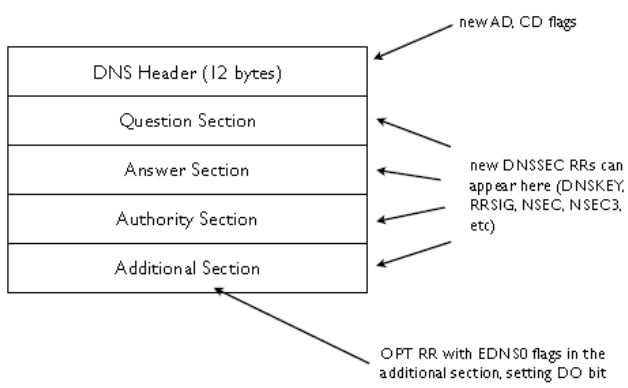
Il flag CD

CD - *"Checking Disabled"*

- Querier imposta il flag CD per indicare che "in sospeso" (dati non autenticati) è accettabile, ad es. perché è disposto a fare la propria convalida crittografica delle firme.

I server abilitati DNSSEC non devono tuttavia restituire dati "cattivi" (ad esempio con firme errate)

Il formato dei pacchetti DNS

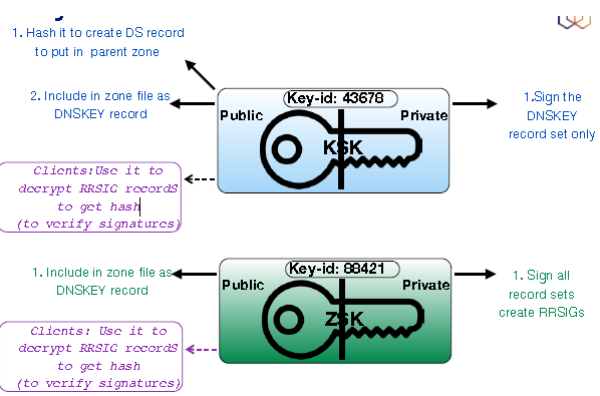


Chiavi

In genere, viene utilizzata una gerarchia a 2 livelli di DNSKEY

KSK: chiave di firma della chiave Firma altre chiavi (può essere più grande, ad es. Più forte e mantenuto offline; utilizzato come punto di ancoraggio della fiducia e certificato dalla zona padre nel DS)

ZSK: chiave di firma della zona Firma tutti i dati nella zona (può avere una forza inferiore e imporre un sovraccarico di calcolo inferiore; può essere modificato senza coordinamento con la zona genitore)



Esempio DNSSEC

```

$ dig jabber.upenn.edu AAAA +dnssec

;; ->HEADER<- opcode: QUERY, status: NOERROR, id: 690
;; flags: qr aa rd ra QUERY: 1, ANSWER: 2, AUTHORITY: 3, ADDITIONAL: 7
;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags: 0, udp: 4096
;; QUESTION SECTION:
; jabber.upenn.edu.      IN AAAA

;; ANSWER SECTION:
jabber.upenn.edu.      86400 IN AAAA 2001:468:1802:101::805b:2ac
jabber.upenn.edu.      86400 IN RRSIG AAAA 5 3 86400 20090719232943 (
20090619232359 23382 upenn.edu.
26b0ACM4oo jEX/zVNIJfHmZ/LSu vn5Fo 8iHcVqV/NBzT
JObOLi taOQVqKCKx smH0TDQgmQia yaL6xGkoyHo 7T32
i 3pEFb d kbNwd #47GQktB221BY12Uzrd+/PmAA2xq J2P
ZIDNbi jkd4 1oRD098BAmYEGG3D b8Dyectx8L/Q= )

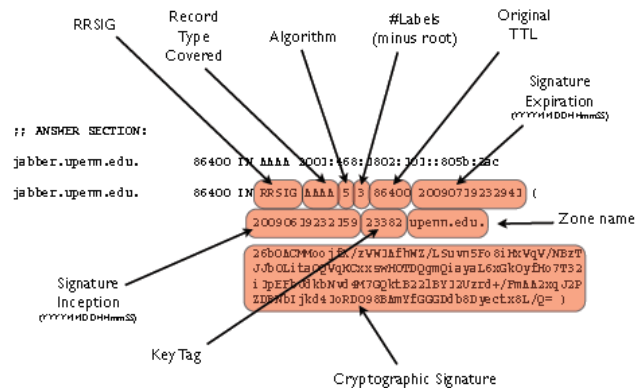
;; AUTHORITY SECTION:
upenn.edu.             86400 IN NS dns1.udel.edu.
upenn.edu.             86400 IN NS noc3.dccs.upenn.edu.
upenn.edu.             86400 IN NS dns2.udel.edu.
upenn.edu.             86400 IN NS noc2.dccs.upenn.edu.
upenn.edu.             86400 IN RRSIG NS 5 2 86400 20050719232217 (
20090619223616 23382 upenn.edu.
WMPt4uD9p3sOR4+207pRIZ46+Qo3 chj9 tnjxh62X tQcER
yuov7+3iHlIM1HC ddk jsddskt8GJ+3he xykb8 fEIJSL i
bqG6hCmC cGdt8GxmP cGdl x95H7NF2y fLGLAcSCix6I
EJb8Aj4+OM9Zq ldmeZrnJDX Sxm8 joQq5+ILk xR4= )

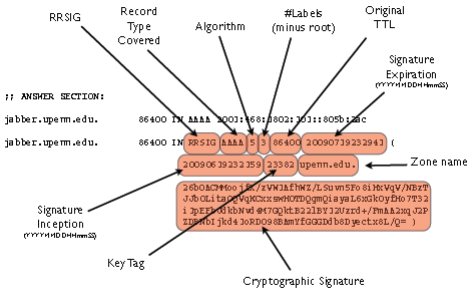
```

Authenticated Data

Answer & Signature

DNSSEC OK





Algorithm# Algorithm

5 RSA/SHA1 (default in BIND 9)

6 DSA-NSEC3-SHA1

7 RSA-NSEC3-SHA1

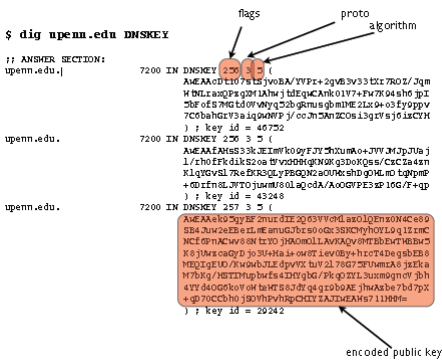
8 RSA/SHA256

10 RSA/SHA512

12 ECC-GOST

13 ECDSA Curve P-256 SHA256

14 ECDSA Curve P-384 SHA384



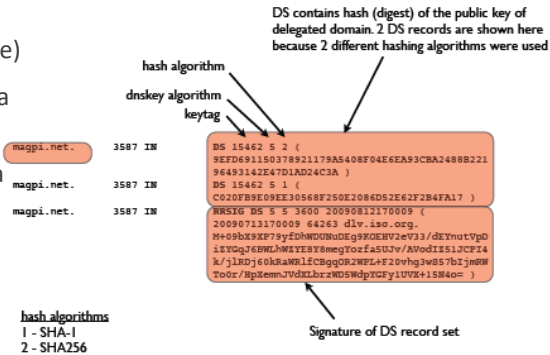
Secure delegation

Indicato dal record DS (Delegation Signer)

Appare nella zona di delega (ovvero genitore)

Contiene un hash della chiave pubblica della zona figlio

La convalida dei resolver utilizza la presenza del record DS e la relativa firma (RRSIG) per autenticare in modo sicuro la delega



Parent and child zone

A DS record in a parent zone refers to a specific DNSKEY record in a child zone

```
upenn.edu. 86247 IN DS 18463 5 2 ( 60039923226DA06785C9E30B259750FAB0960BF57054B DDFDEEE1188977DAB88 )  
upenn.edu. 86247 IN DS 18463 5 1 ( 0C45B3D090B221E0E33BBEBSA619D89416BAF197 )  
upenn.edu. 86247 IN RRSIG DS 8 2 86400 ( 20131004044110 20130927033110 21638 edu. p1BkiV626itFwzUd0rKs1171jBm2+EU0WYEsuK0hW2kw 7Gape80gTWSkaftTfLB7AjNN8AR85YrEH56KXwEvRoo1 yN2Tz1EE0eLtiQnMEwAiofEZ7NKz7eb2IMezGtFvUqBm x0gf2B5r4JHFhyB74M10+BY16LMyeoujUsezDOw= )
```

```
upenn.edu. 7200 IN DNSKEY 257 3 5 ( AwEAAf02wZEMtX2ofTKfJ/xoQffn17NFJV0YSz4F3tMd kktC/abDax+8BOMJHRAoznigKoircdVL7EbV82DYRoUvJ v44VLRELLbggDnnpP4fCJ88Tu33/SGFZwmgsoo40A6y xhwEniIveQ5B7LJ0Vh8RyfgU6obu7wFR7pBV1UVybLZf F3n1Kb+6KRWtaw5JLbhfYEXYxhUpVWlbeXYmoroo09SH sQaoR3vr7L16HEe4VRE+8KouNRkzLBG5XQDnImYanv6 P4tYasITCYPgkKSVJKeGudnoJoxZ8NRAgOnoGDgQML3K ALGWHWlRpmEN6EQdf7+qvlvm7uHwN1LOMh87B4U= ) ; KSK; alg = RSASHA1; key id = 18463  
[ ... other DNSKEYs and RRSIGs omitted ... ]
```

Risposte Negative

“Authenticated Denial of Existence”

- NSEC or NSEC3 records (and their signatures)

Concatenare i record DNS in una zona come se coprissero gli spazi tra i nomi nella zona

Necessario ordinamento canonico dei nomi nelle zone firmate (RFC 4034, sezione 6.1) •

Necessario a causa del modello di firma precalcolato di DNSSEC (problemi di calcolo e sicurezza della chiave di firma)

Ordina i nomi DNS in ordine di più significativo (più a destra) prima le etichette. Quindi, all'interno di ciascuna etichetta, ordinale come otetto stringhe, da lettere ASCII a maiuscole e minuscole.example.com

a.example.com
blah.a.example.com
Z.a.example.com
zABC.a.EXAMPLE.com
z.example.com
\001.z.example.com
*.z.example.com
\200.z.example.com

Authenticated Denial-of-Existence

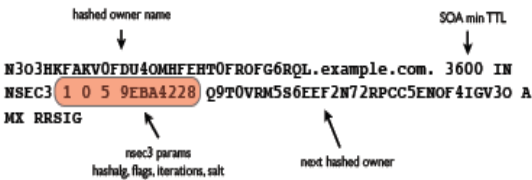
Most DNS lookups result in denial-of-existence

NSEC (Next SECure)

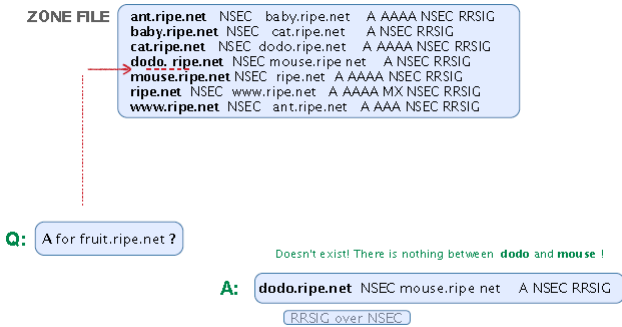
- Lists all existant RRs associated with an owner name
- Easy zone enumeration

NSEC3

- Hashes owner names
 - Public salt to prevent pre-computed dictionaries
- NSEC3 chain in hashed order
- Opt-out bit for TLDs to support incremental adoption
 - For TLD type zones to support incremental adoption
 - Non-DNSSEC children not in NSEC3 chain



Esempio NSEC



Adozione di DNSSEC

E' considerato un elemento fondamentale nelle strategie globali della cosiddetta trusted Internet

In realta la sua adozione langue:

Complessità delle configurazioni

Aumento del traffico

Perplessità di una parte della comunità sull'efficacia

Nel 2009 risultavano 274 domini su circa 80'000'000 di .com

- DNSSEC Root signed (July 2010)
- Many TLDs signed:123 of 318 (39%) as of Sept 2013 (112 w/ DS):
- GTLD: edu gov com net org biz info arpa
- ccTLD: many, including a number of IDNs
- See http://stats.research.icann.org/dns/tld_report/
- Also <http://www.huque.com/app/dnsstat/category/tld/>
- Reverse trees: in-addr.arpa ip6.arpa
- Note: not all TLD registrars support DNSSEC yet (ie. ability toinstall a DS record in the TLD)

Limiti di DNSSEC

Secondo D. J. Bernstein, autore di djbdns e di una proposta alternativa (DNSCurve), è mal progettato:

L'assunzione di base è che non è pensabile usare la crittografia in ogni pacchetto, per ragioni di efficienza.

Non c'è crittografia dei dati (solo integrità)

Le firme sono precalcolate (e quindi occorre ruotare le chiavi per limitare i replay)

Tutti i tool per la modifica dei dati DNS devono essere 'signature aware'

Non c'è protezione contro DoS



Alternative: DNSCurve

<http://dnscurve.org/>

- Some people think this is a competitor to DNSSEC, but it really isn't
 - Encrypts/authenticates packets between resolvers and authoritative servers
 - Uses very fast elliptic curve crypto
 - DNS caching model better suited to object security, where response can come from any entity (authority, forwarder, intermediate cache, etc), but we can still authenticate the "data" inside the response
 - But, we may need transport security as well
- 

Summary

Core protocols not designed for security

More secure variants exist

IP → IPsec

DNS → DNSsec

BGP → SBGP